

# Password & MFA Policy

IT-01 | Version 1.0 | Effective 01 September 2026

Owner: IT & Security | Applies to employees and contractors

Fictional company policy for RAG training and evaluation. All .example addresses are placeholders; these are not live services.

## 1. Purpose and scope

Protect Northstar Analytics accounts against unauthorized use. This policy applies to employees, contractors and administrators using company accounts, including email, the support portal, VPN and business applications.

## 2. Password rules

Passwords must contain at least 14 characters; spaces and passphrases are allowed. Do not reuse a company password for personal accounts or share it with anyone. The identity service rejects known compromised passwords. Use the company-approved password manager to generate and store unique passwords. Routine password changes are not required; change a password immediately if compromise is suspected or Security instructs you to do so.

## 3. Multi-factor authentication

MFA is required for all interactive company sign-ins, including VPN access. Register a security key or the company authenticator app before the first sign-in. SMS is not an approved MFA method. Administrators must use a hardware security key for privileged access. Reject any MFA prompt you did not initiate and report it immediately under IT-05.

## 4. Failed sign-ins

After 5 consecutive failed password attempts, the account is locked for 15 minutes. Wait for the lock to expire or contact IT Support. Repeated lockouts or unfamiliar sign-in alerts must be reported immediately. A lockout does not remove the MFA requirement.

# Password & MFA Policy

## Procedures and responsibilities

### 5. Password reset

Use <https://identity.northstar.example/reset> and complete verification with a registered MFA factor. If no factor is available, contact IT Support at <https://support.northstar.example>. Support verifies identity through a live video check against the staff directory and confirmation from the recorded manager through an existing company channel. Support never asks for your password, an MFA code or approval of an unsolicited prompt.

### 6. Lost factor and recovery

Report a lost security key or phone immediately. Support revokes the missing factor and active sessions after identity verification. A temporary enrollment pass expires after 30 minutes and can be used once; it is issued only to register a replacement factor. Register the replacement before normal access resumes. Store recovery codes in the approved password manager, separate from the device used for MFA.

### 7. Service accounts and exceptions

Non-interactive service credentials are stored in the managed secrets vault, never in source code or tickets. Their owner rotates secrets at least every 90 days and immediately after suspected exposure. Any exception requires written Security approval, a named owner and an expiry of no more than 30 days. No exception may authorize sharing passwords.

### 8. Related policies

Use IT-03 for VPN eligibility, IT-04 for granting or removing access, and IT-05 for reporting suspected credential compromise.